HIRATA 客戶訂單履歷管理系統
入口網站介面規格說明

對象　台灣平田機工股份有限公司　入口網站開發／維運負責人
目的　說明三個接點的規格，並列出需要貴端提供的資訊
提出方　普魯士（訂單系統開發方）

這份文件是什麼

HIRATA 客戶訂單履歷管理系統（以下簡稱「訂單系統」）與貴公司入口網站的整合方式已經談定。這份文件說明三個接點各自要怎麼運作，並在每一節末尾標出**需要貴端提供的資訊**。

您不需要在這份文件上填寫任何內容 —— 看完後以任何形式（郵件、文件、口頭會議皆可）回覆各節列出的項目即可。我方會據此撰寫正式的《介面規格書》，並提供對應的 PHP 範例程式碼。

接點	方向	作用	貴端需要做什麼
一　SSO 登入憑證	雙向 兩種進入路徑	使用者進入訂單系統時，帶著一張「這個人是誰」的簽章憑證。使用者可能從入口網站點進來，也可能直接開訂單系統（書籤、email 通知）再被送去登入	新增一段產生憑證的程式 ＋ 兩個進入點
二　通知接收 API	訂單系統 → 入口網站	訂單系統有待簽核的事，推一則通知到貴端的通知中心	新增一支 API
三　登入狀態查詢 API	訂單系統 → 入口網站	使用者在入口網站登出後，訂單系統要能跟著登出	新增一支 API

> 若其中任何一項貴端無法提供，也請告知 —— 每一節都寫明了替代方案與影響，我方會據此調整。

說明：藍／綠色為 HIRATA
已確認或可提供事項；橘色為待開發／待雙方定案；紅色為正式上線前必要事項。

整體環境前提 已確認

DWP 與訂單系統均為公司內網系統，本案 SSO、通知 API、登入狀態查詢均於內部網路運行，不因本案直接對 Internet 開放。

接點一：SSO 可行／需開發

DWP 為 Ubuntu 24.04 + Nginx 1.24 + PHP 8.3.6 FPM，自製純 PHP；目前沒有既有 SSO。OpenSSL 可支援 RS256，將新增 SSO Start／Ticket 核發能力。

接點二：通知 API 可行／需開發

DWP 已有既有通知 Worker 流程，可新增 Order Notification Receiver API，驗證後投入既有 notification queue，不直接寫最終通知表。

接點三：登入狀態 API 可行／需開發

目前 PHP File Session 不適合直接供外部查詢；將採獨立隨機 sso_sid，Order 只查該登入階段是否 active／ended，不暴露 PHPSESSID。

一 SSO 登入憑證（ticket）

貴端新增一段程式

使用者進入訂單系統時，入口網站產生一張短效的簽章憑證隨行。訂單系統驗章後即認得這個人，不需要再登入一次。

兩種進入路徑都要支援

使用者不是只會從入口網站進來。以下兩條路徑都很常見，**貴端需要各提供一個進入點**：

路徑	由誰發起	什麼時候會發生
A　從入口網站進入	入口網站	使用者在入口網站點「訂單系統」，或點了通知中心裡的待簽核項目
B　從訂單系統進入	訂單系統	使用者直接開訂單系統網址（書籤）、點了**email 通知**裡的連結，或原本開著的分頁登入已過期

路徑 A —— 入口網站主動送人過來：

```
使用者在入口網站點「訂單系統」(或點通知)
  → 入口網站產生 ticket (JWT 格式，內含員工編號)
  → 導向 https://<訂單系統網址>/api/v1/auth/sso/callback?ticket=xxx
  → 訂單系統驗章 → 查員工編號 → 放行
```

路徑 B —— 訂單系統把人送去登入，再接回來：

```
使用者開 https://<訂單系統網址>/#/quotation/158 (尚未登入)
  → 訂單系統導向 https://<入口網站網址>/sso/start?return_to=%2Fquotation%2F158
      ├─ 使用者在入口網站已登入 → 直接產生 ticket
      └─ 尚未登入 → 顯示登入頁，登入成功後再產生 ticket
  → 導回訂單系統的 callback (網址寫在貴端設定檔)，原樣帶回 return_to
  → 訂單系統驗章 → 放行 → 導向 return_to 指定的頁面
```

回跳網址請寫在貴端的設定檔裡，不要從網址參數讀取。

路徑 B 若設計成由訂單系統用參數指定完整的回跳網址（例如 `?from=https://...`），入口網站就會變成開放轉址的破口 —— 有心人只要誘導使用者點一個帶著自己網址的連結，入口網站就會把**一張能登入訂單系統的有效憑證**送到那個網址。外洩的不是網址，是憑證本身，等同帳號被接管。

所以訂單系統只傳 `return_to`，而且**只會是站內的相對路徑**（如 `/quotation/158`），不含網域。貴端只要原樣帶回即可，不需要驗證它 —— 該由訂單系統負責，我方本來就會擋掉非站內路徑。

路徑 A：入口網站 → 訂單系統 同意

DWP 可提供「訂單系統」及通知點擊入口。登入成功後核發短效 Ticket，再導向 Order callback。

路徑 B：訂單系統 → DWP → 訂單系統 同意

DWP 可新增 /sso/start 類入口；未登入時先完成 DWP 登入，再接續原 return_to。正式 Path 於介面規格書定案。

return_to 同意原則

僅接受訂單系統站內相對路徑；Order callback 主機／URL 固定寫於 DWP 設定，不由外部參數指定。建議再加入 request_id/state 供一次登入流程對應。

Ticket 傳遞方式 需調整／確認

目前 DWP Nginx access log 會記錄完整 Query String。若直接使用 ?ticket=<JWT>，JWT 會落入 access log／browser history。建議正式規格改用一次性 code、POST/form_post，或至少完成 log redaction + 驗證後 clean redirect。

憑證的欄位

我方建議採用下列欄位。這是刻意設計為 OIDC 標準的子集 —— 日後若貴端要升級為正式 OIDC，訂單系統只需替換驗證元件，其餘不動。

欄位	內容
`iss`	入口網站識別字串，例 `hirata-portal`
`aud`	訂單系統識別字串，例 `hirata-order`
`sub`	**員工編號**
`exp`	簽發後 60 秒
`iat`	簽發時間
`jti`	每張憑證唯一的識別碼（防重放用）
`sid`	**入口網站的登入階段識別碼**（session id 或其雜湊值）

安全要求

- 憑證有效期 **60 秒**，且**用過即焚** —— 我方會記錄 `jti`，同一張重複出現一律拒絕
- 簽章演算法**建議 RS256**：貴端持私鑰簽章，我方只需公鑰驗章。萬一我方這側外洩，也不會有人能冒充貴端簽發憑證
- 金鑰不進版本控制，以環境變數管理

> **`sub`（員工編號）請務必以字串型別傳送，不要轉成數字。**
>
> 我方既有帳號中有 `0906`、`0985` 這類**帶前導零**的編號。若在貴端的程式裡該變數是整數型別，`json_encode` 會輸出成 `{"sub":906}` —— 前導零在到達我方之前就消失了，該員工會登不進系統，而且從我方的日誌上看起來像是「查無此帳號」，不容易聯想到型別問題。
>
> 正確：`{"sub":"0906"}`　　錯誤：`{"sub":906}`

> **`sid` 是接點三的前提。**它讓我方知道這次登入來自入口網站的哪一個登入階段，接點三才能問「*這一次登入*還有效嗎」而不是「這個人還登入著嗎」——兩者的差別見接點三的說明。
>
> 可以直接送 session id，也可以送它的雜湊值或另建一組對應碼，只要**同一個登入階段內固定不變、不同登入階段不重複**即可。我方只拿它來比對，不解讀內容。

iss — 可提供

建議值：hirata-portal；最終值由雙方規格書定案。

aud — 可提供

建議值：hirata-order；最終值由雙方規格書定案。

sub — 已確認

exp / iat — 可提供

jti — 可提供／需開發

sid — 可提供／需開發

不使用原始 PHPSESSID。新增獨立隨機 sso_sid；DB 僅存 SHA-256 hash，Order 取得明文只用於 Session Status 查詢。

簽章 — 同意 RS256

PHP OpenSSL 已具 RSA SHA-256 能力。私鑰放 Web root 外，Order 僅持公鑰；建議 JWT header 增加 kid 以利輪替。

需要貴端提供

1. 入口網站的**正式與測試環境網址**
2. **路徑 B 的進入點網址**（例如 `/sso/start`）—— 需能在使用者尚未登入時顯示登入頁，登入成功後接續原本的導向
3. 確認會把 `return_to` **原樣帶回**，且回跳的訂單系統網址寫在貴端設定檔、不從參數讀取
4. 使用的 **PHP 框架與版本**（我方據此提供對應的範例程式碼）
5. 採用 **RS256 或 HS256**，以及金鑰的交換方式與輪替頻率
6. 員工**離職時入口網站如何處理該帳號**（停用或刪除）
7. 上表欄位中**貴端無法產生的項目**（特別是 `jti` 與 `sid`：前者若無法產生，我方需改用其他防重放做法；後者若無法產生，接點三只能退回以員工編號查詢，精確度會下降）

若貴端已與其他系統做過 SSO，請直接告知使用的機制 —— 沿用既有機制通常比新做一套省事，我方會重新評估。

1. 正式與測試環境網址 — 部分可提供

正式目前為 http://hct.hirata.com.tw/；正式 SSO 上線前必須先完成 HTTPS。獨立 UAT／測試網址尚待建立。

2. 路徑 B 進入點網址 — 需開發

目前不存在；預計新增 /sso/start 或等價 endpoint，實際路徑待規格書定案。

3. return_to 原樣帶回／callback 固定設定 — 可配合

同意 callback 固定於 DWP server-side config；return_to 僅允許 Order 站內相對路徑。

4. PHP 框架與版本 — 已確認

PHP 8.3.6 FPM；自製模組化純 PHP，非 Laravel／Symfony／CodeIgniter。

5. RS256 / HS256、金鑰交換與輪替 — 建議 RS256

DWP 具 OpenSSL 能力；建議 RS256。公鑰交換、kid、rotation、舊 key overlap、emergency revoke 需雙方確認。

6. 員工離職時帳號處理 — 已確認／需補強

離職採停用：employment_status=resigned 並 is_active=0，不刪除。但既有 PHP Session 目前不會立即撤銷；本案上線前需補強。

7. jti / sid — 皆可提供但需新建

jti 可由安全亂數產生；sid 採獨立 sso_sid，不暴露 PHPSESSID。

既有 SSO — 無

二 通知接收 API

貴端新增 API

訂單系統有「輪到您簽核」這類待辦時，會主動推一則通知到貴端的通知中心。**這支 API 的規格由貴端定義**，我方照貴端的格式送出。

我方會送出的內容

以下是我方預設的欄位。若貴端希望使用不同的欄位名稱，請一併告知。

欄位	內容說明	範例值
`source`	來源系統識別	`hirata-order`
`external_id`	這則通知的唯一識別碼	`notification-12345`
`account`	收件者的員工編號	`A00123`
`event`	事件代碼	`approval_step_ready`
`created_at`	發生時間（ISO 8601）	`2026-08-18T10:30:00+08:00`
`title`	通知標題（繁體中文）	報價單 26-T0147 待您簽核
`body`	通知內文（繁體中文）	東元電機股份有限公司的報價單 26-T0147 已送至您這一關，請前往簽核。
`link`	點擊後要前往的完整網址	`https://order.../#/audit-management/...`

```
{
  "source": "hirata-order",
  "external_id": "notification-12345",
  "account": "A00123",
  "event": "approval_step_ready",
  "created_at": "2026-08-18T10:30:00+08:00",
  "title": "報價單 26-T0147 待您簽核",
  "body": "東元電機股份有限公司的報價單 26-T0147 已送至您這一關，請前往簽核。",
  "link": "https://order.hirata.com.tw/#/audit-management/quotation-approval/42/7"
}
```

語系：現階段只推繁體中文。若貴端通知中心日後要支援日文／英文，請先告知 —— 我方會把欄位結構改為可容納多語，這屬於介面變更，需雙方協調版本。

API 規格由 HIRATA 定義 — 同意

建議採版本化 endpoint，例如 POST /api/integrations/hirata-order/v1/notifications；實際 Path 於正式規格書確認。

source — 同意

固定識別 hirata-order。

external_id — 同意且必要

作為 idempotency key。建議 UNIQUE(source_system, external_id)；同 id、同 payload 回既有結果；同 id、不同 payload 回 conflict。

account — 可對應

event — 同意

保留事件代碼；需共同定義事件清單及哪些事件需進 DWP。

created_at — 同意

採 ISO 8601；系統判定／簽章 timestamp 建議仍用 UTC epoch。

title / body — 第一階段可繁中

link — 可接受但須限制

重複推送的去重（此項不可省）

網路逾時等情況會讓我方重試，因此**同一則通知有可能送達兩次以上**。貴端必須以 `external_id` 判斷是否已收過，已收過就直接回成功、不要重複寫入。

這不是可選項 —— 少了它，使用者的通知中心會出現重複訊息。

需要貴端提供

1. 接收端點的**正式與測試環境網址**、HTTP 方法與 Content-Type
2. **認證方式**：我方建議 HMAC 簽章（請告知放在哪個 header、密鑰如何交換）。若採固定 Token 或 IP 白名單也請說明

   建議至少採用 HMAC 簽章。只用固定 Token 的話，Token 一旦外洩，任何人都能往貴端的通知中心塞假通知。
3. 若**希望使用不同的欄位名稱**，請提供對應表
4. **成功與失敗時的回應**（狀態碼與格式），以及哪些狀態碼不應該重試
5. **確認會實作去重**，以及負責的窗口

若入口網站伺服器無法接收外部主動發送的 HTTP 請求，請告知 —— 我方將改為由貴端定期來查詢的方式，屆時需要貴端說明可接受的查詢頻率。

去重 可實作

DWP 既有通知機制已有 dedupe_key；本案另建 external receipt／mapping 會更利於重送、對帳與錯誤查詢。

1. Endpoint / Method / Content-Type 待建

建議 POST + application/json；正式／UAT URL 待 HTTPS 與 UAT 環境建立後提供。

2. 認證方式 建議 HMAC-SHA256 + IP Allowlist

DWP 已有 HMAC(timestamp + nonce + body hash) 與 Redis replay guard 可重用。Order 正式／測試來源 IP 需由普魯士提供。

3. 欄位名稱 原則可沿用

source、external_id、account、event、created_at、title、body、link 可作為基礎；最終型別／長度／必填規則需介面規格書定案。

4. Success / Error / Retry 需共同定義

建議 2xx=成功或重複；400/401/403/409/422 原則不重試；429/5xx 可重試。需雙方確認 timeout、retry 次數、backoff。

5. 去重窗口 HIRATA 可負責

由 HIRATA 接收端實作；建議增加 receipt table 及介接 audit。

三 登入狀態查詢 API

貴端新增 API

使用者在入口網站登出後，訂單系統要能跟著登出。做法是**訂單系統每 10 分鐘問一次**「這一次登入還有效嗎」，而不是要求貴端在登出時主動通知我方。

這樣設計的好處是**貴端的登出流程一行都不用改** —— 只需提供一支唯讀的查詢 API。使用者可能從多條路徑登出（按鈕、逾時、關閉瀏覽器），要求貴端在每一條路徑都插入對外呼叫，漏掉任何一條就會失效。

查的是「這一次登入」，不是「這個人」

這個區別會直接影響功能對不對。我方查詢時帶的是接點一 ticket 裡的 `sid`（該次登入的階段識別碼），而不是員工編號：

情境	以員工編號查	以 `sid` 查
使用者在公司電腦登出入口網站，手機仍登著	回「還登入」→ 公司電腦的訂單系統**不會登出** ❌	該階段已結束 → **正確登出** ✅
使用者在手機登出，公司電腦仍登著	回「還登入」→ 不登出 ✅	公司電腦那個階段仍有效 → 不登出 ✅

第一列就是必須用 `sid` 的理由 —— 使用者在這台電腦明明按了登出，訂單系統卻還開著，正是這個機制要避免的情況。

我方需要知道的答案

只有兩種：該登入階段**仍有效**，或**已結束**。不需要任何使用者資料。

錯誤語意

我方會嚴格區分「**答案是已登出**」與「**問不到答案**」—— 兩者混在一起的話，貴端一故障就會把所有人踢出。以下是我方的判定方式，**請確認與貴端的回應設計一致**：

貴端的回應	我方判定	對使用者的影響
200，內容表示仍有效	正常	繼續使用
200，內容表示已結束	已登出	**立即登出**

查詢方式 同意

Order 每 10 分鐘查 sso_sid 是否仍有效的方向可行；查詢不得 touch DWP PHP Session，也不得因此延長 DWP idle timeout。

查的是「這一次登入」 同意

Active 判定 需明確定義

active 必須同時滿足：sso_sid 未 ended、未超 idle／absolute expiry、帳號仍 is_active=1 且 employment_status=active。

200 active / 200 ended 可配合

建議 HTTP 200 + 明確 JSON state；不得回傳多餘使用者資料。

查無 sid 原則視同 ended

貴端的回應	我方判定	對使用者的影響
查無此 `sid`	視同已登出	**立即登出**（請見下方確認事項）
逾時、5xx、連線失敗	問不到答案	不動作，計數 +1；**連續 3 次**（約 30 分鐘）才登出
4xx（認證失敗、參數錯誤）	我方設定錯誤	不登出使用者，發出告警由我方排查

逾時與來源

- 我方的請求逾時設為 **3 秒**。超過即視為「問不到答案」，不會登出使用者，但請確認貴端的 API 能在此時間內回應
- 若貴端要做 IP 白名單，我方會提供正式與測試環境的**對外 IP**（待正式環境確定後提供）
- 呼叫頻率為**每位使用者每 10 分鐘一次**，且僅在使用者的分頁處於前景時發出 —— 背景分頁不會持續呼叫

需要貴端提供

1. 查詢端點的**正式與測試環境網址**與 HTTP 方法
2. `sid` **如何傳遞**（query 參數或 request body，以及參數名稱）
3. **認證方式**（可與接點二相同，請註明）
4. **回應格式**：仍有效、已結束兩種情況各自的狀態碼與內容
5. **「查無此 `sid`」要如何判定**——我方預設視同已登出。若貴端會定期清除舊的 session 紀錄，可能造成使用者被提早登出，這種情況請告知，我方需改用其他判定
6. **預估同時在線人數**與可接受的呼叫頻率，以及是否有速率限制
7. 是否需要我方提供**對外 IP** 以設定白名單

若貴端無法提供這支 API：入口網站登出後，訂單系統不會跟著登出，僅保留「閒置 30 分鐘自動登出」的保護。使用者在入口網站按登出後，若立刻回到訂單系統的分頁仍可繼續操作，最長至閒置滿 30 分鐘為止。

若貴端有資安稽核要求，請特別評估此缺口是否可接受。

逾時 / 5xx / 連線失敗 — 同意 Fail-Open 短期策略

4xx — 同意

1. Session Status Endpoint — 待建

正式／UAT Path 待定；建議使用 POST，避免 sid 進 access log query string。

2. sid 傳遞 — 建議 request body

JSON body 傳 sso_sid；不使用 query parameter，亦絕不傳 PHPSESSID。

3. 認證方式 — 建議同通知 API

HMAC-SHA256 + timestamp + nonce + replay guard + optional IP allowlist。

4. 回應格式 — 可定義

建議 state=active / ended；5xx 僅表示「問不到答案」，不可等同 ended。

5. Unknown sid — 原則 ended

但需先完成 registry retention／cleanup 契約。

6. 在線人數／頻率 — 能力足夠，仍待數字確認

現有 5 分鐘 activity snapshot 僅可估活躍使用者，不等於 authoritative Session 數；待 sso_sid registry 建立後可精確計算登入階段。10 分鐘輪詢負擔預估低。

7. IP 白名單 — 可做

後續流程

1. 貴端回覆三個接點所需的資訊
2. 我方據此撰寫《介面規格書》v1.0，送請貴端確認簽署
3. 我方提供 PHP 範例程式碼（接點一的憑證產生、接點三的查詢 API）
4. 我方提供測試工具，讓貴端在訂單系統還沒接上前就能自行驗證接點二的接收端點
5. 雙方各自開發，完成後進行聯調

> 規格書簽署前，雙方都不建議開工 —— 規格未定就寫的程式碼有很高機率白做。

附錄｜名詞對照

本文用語	意思
我方	普魯士（訂單系統的開發方）
貴端 / 貴公司	台灣平田機工股份有限公司
訂單系統	HIRATA 客戶訂單履歷管理系統
入口網站	台灣平田機工股份有限公司自建的 PHP 入口網站（含通知中心）
ticket	接點一那張短效的簽章憑證
`sid`	入口網站的登入階段識別碼，由接點一的 ticket 帶入，接點三用它查詢
員工編號	兩系統用來對應同一個人的唯一識別
簽核	訂單系統中的審核流程（報價單、專案、Service 的核准）

任何一項不確定的，直接告知我方窗口，我們會一起討論。不確定而先給一個估計值，比留著不談更難發現問題。

後續流程 同意

開發前置條件 重要

正式開發前需先完成：① DWP HTTPS/UAT；② Ticket 傳遞避免 JWT 落入 query/access log；③ sso_sid lifecycle；④ 帳號停用立即撤銷機制；⑤ API authentication / error / retry contract。

請普魯士另提供 待取得

Order 正式／UAT URL、IP/來源 IP、Port、routing；callback；RS256 public-key 驗證方式、kid/rotation；Order NTP/clock skew；notification retry／timeout；UAT 驗收案例。

文件定位 建議